

REDTEAM 商业计划书

智能体安全评测、整改复核与持续回归服务（大陆合规、不发币）

文档性质声明：本计划书是**拟议方案的讨论稿**，不是法律意见、合规认证、监管许可或对任何客户的交付承诺。文中不包含真实客户、已签合同、已发生收入或经审计的市场规模数据；所有客户与收入内容均为**待验证假设**。实施前须由专业律师按实际业务、数据流与服务对象复核。文档不含私人联系方式、主机信息或任何凭据。

1 执行摘要

一句话定位：在企业让 AI 智能体接触采购、审批、支付建议等业务之前，REDTEAM 在**书面授权、合成或脱敏数据、隔离的测试环境**里验证它是否越权、是否完成正常任务、修复后是否复发，交付可复现的证据和上线验收报告。

解决的问题：智能体会读商品页、邮件和工具结果并建议或调用工具。外部内容可能把“参考信息”伪装成授权——改收款人、改金额、重复付款、越权审批、敏感数据外泄。只统计模型回答或“拒绝率”是不够的：必须区分**违规提议、平台拦截、实际执行、合法任务完成**，并记录错误与未覆盖项。全盘拒绝业务不能算“安全且可用”。

客户购买什么：人民币计价的安全评测、整改复核与持续回归服务，交付证据包与验收报告。不是支付、代币、交易所、众筹、匿名悬赏或面向真实目标的攻击平台。

能力现状（诚实表述）：已有本地合成支付场景和攻防评测的研究原型（开源：github.com/Fishman-free/REDTEAM），包含授权任务、模拟付款执行、程序化裁决、候选修复、回归与报告的完整离线闭环，以及覆盖 L0–L3 四个难度级别（不允许付款 / 单笔付款 / 限额支付 / 多智能体协作）的 43 个场景种子。拟将该能力重构为企业封闭授权的评测服务；首期不发币、不碰真实资金、不开放公共攻击平台。

三条路线，按顺序启动而不是同时启动：

路线	首期决策	边界
企业封闭授权评测（ 主线 ）	MVP：签授权与数据处理约定，以合成/脱敏场景做私有离线评测，交付报告	明确目标、时段、可测操作、停止条件、验收标准；不连真实资金系统
黑客松/挑战赛（后续可选）	先办受邀、封闭、无公开有偿悬赏的小范围演练	另行完成规则、身份、隔离、审核与披露审查后再决策
RTM/区块链激励	明确排除 于商业版	历史研究组件（代币与奖励合约）如实说明，与商业产品的代码、部署、网站、条款和资金流实质隔离

2 目标客户与市场假设（待验证）

候选客户画像（均待验证，未有任何既成客户）：

- 做采购、财务或审批 workflows 的企业软件厂商——其产品开始内嵌 AI 助手，需要上线前验收；
- 有智能体项目的企业安全团队——需要红队式演练与修复复核；

3. 园区与孵化器内有智能体落地需求的团队——需要合规辅导对接与联合验证。

首个样板场景：企业授权智能体为已验收订单发起付款建议。用合成订单、供应商和预算，在隔离环境测试外部信息诱导改收款人、改金额、提前/重复付款；由测试宿主决定是否模拟落账，并核对正常订单能否完成。首版只做已支持的支付场景子集，不虚构“全领域覆盖”。

拟议收入流（价格与数量须经真实调研后填写，本文不虚构数字）：

- 一次性评测费（按项目/场景包计价）；
- 上线前整改复核费（修复后回归验收）；
- 年度回归订阅（版本升级后的历史问题回归）；
- 经审查的企业私有化部署与维护费。

全部按正常人民币合同、开票、纳税处理；不收币、不抽成分、不代收付。

3 产品：MVP 范围

MVP 六项功能：

1. **委托与范围登记：**项目、客户授权文件引用、目标版本、环境、允许输入面、测试窗口、责任人、禁止动作、紧急停止开关；授权缺失默认不能创建可执行评测（fail-closed）。
2. **夹具与执行隔离：**合成/脱敏场景包、确定性基线、独立测试账本；被测目标不能自写评分或授权事实，不能触真实资金。
3. **受控用例运行：**正常任务与攻击任务配对，记录任务版本、注入面、输入摘要、工具请求、宿主批准/拒绝、实际模拟事件、运行错误；每个用例的预期证据可机器校验。
4. **可信裁决：**按授权、对象、金额、次数、审批、幂等判断；passed / failed / error / unsupported 四态，未实现项不计通过；区分模型阻止与平台阻止、提议与实际落账。
5. **复核交付：**可复现证据包、风险分级与限制、修复建议、正常任务完成率与覆盖率、修复前后对照、历史问题回归；人工复核签收。
6. **访问与治理：**最小权限、租户隔离、审计、保留/删除策略、秘密管理、私密漏洞处置；首版默认单租户/本地部署。

MVP 明确不做：公开攻击注册/悬赏、自动探测真实网站、主网或真实资金、发币/链上奖励、未授权代码执行、自动对外披露、客户敏感内容发往未知或境外模型、宣称“自动修复可上线”。

差异化：不只看模型说了什么，还看它实际做了什么；同时考核安全与办事能力；修复必须有对照、回归与失败回滚；判据在评测前冻结（预注册），不接受事后解释。不声称独有或已领先竞品。

4 技术架构与现状

评测管线（不预设框架）：

授权/项目管理 → 只读夹具与范围门禁 → 受控测试执行器 → 宿主侧事件/账本 → 独立裁决 → 证据仓库 → 人工审核/报告 → 回归计划

信任边界：外部页面/消息/工具结果是不可信数据；被测 Agent 的输出只是**请求**；授权事实与执行/裁决由宿主维护；被测对象、参赛者或客户夹具不能覆写评分和账本。默认不开外网出口；确需模型服务时，先审查供应商、委托处理、数据去向与出境问题并取得客户书面授权。

已有研究原型（可抽取的评测内核候选）：

- 双入口身份授权核验：用户通道经身份核验形成可执行授权，外部通道内容一律是数据（“商户说”用户同意了“不算授权”有显式判据）；
- 程序化裁决：三个事实（违规请求/实际落账/正常完成）+ 四态结果 + 预注册判据；
- 场景分级 L0-L3：不允许付款 → 单笔付款 → 限额支付 → 多智能体协作（采购—审批—支付三角色）；
- 攻击工程：多轮升级对话、聊天记录伪装、攻击手法多样性管理；
- 修复验证：攻击→执行→裁决→候选修复→回归→晋级/回滚闭环，全部度量来自宿主账本；
- 本地可核验模拟付款与事件记录（本地 EVM/SQLite 为研究组件，商业首期用普通数据库、签名日志与访问控制即可，区块链是可选技术、不是商业前提）。

能力边界（对外表述同样适用）：默认确定性模拟模型与合成资产；研究靶场有故意保留的漏洞，不可公开暴露；容器与哈希日志不是完全隔离或绝对不可篡改的证明；确定性离线结果不代表真实大模型抗攻击率。

5 合规框架（风险清单，待专业复核）

以下为经营模式的初步风险识别，**不是法律意见或主管部门许可**；上线前按实际业务逐项确认。

A. 虚拟货币与融资（最高优先级）：原始研究含 RTM 可转让代币与奖励合约，不能对外掩盖。境内商业首期移除发行、交易、兑换、变相融资、收益承诺与境外交易导流；不以“去中心化”“测试币”“改名积分”规避。研究代码与商用部署、网站、条款、资金流实质隔离。奖励如确需，另设封闭授权规则、以固定人民币预算经合规主体支付；最稳妥首期不设公开有偿悬赏。

B. 授权测试与漏洞治理：书面授权限定目标、时段、权限、手段、频率、数据处理与停止条件；禁止无授权真实目标扫描/攻击。建立漏洞私密接收、修复协同、负责任披露与留痕；未公开漏洞不得提供给产品提供者之外的境外组织或个人，不上传境外模型、不公开、不上公开榜单。

C. 个人信息、商业秘密与数据出境：合成数据优先；必要时脱敏、最小化、分类分级、访问控制、保留期与删除；真实材料送模型前明确委托处理与供应商责任，境外模型调用不等于当然允许；是否构成重要数据/个人信息出境逐项判断。

D. AI、网站与区块链服务：仅企业内部研发、不向境内公众提供生成式 AI 服务的，不适用生成式 AI 暂行办法的范围，但仍受其他法律约束；面向公众则重新评估。算法备案/安全评估按具体条件判断；提供境内区块链信息服务需评估备案等法定义务；网站按实际经营确认 ICP 备案/许可；**备案不等于行政许可或政府背书，ICP 备案不能替代金融、支付业务许可。**

E. 生产与资金：模拟合约不是支付牌照。未来真实付款由客户自有系统或持牌机构处理，平台不托管资金、不代收代付、不清结算；建议首期只交付测试报告。

主要官方依据（供律师复核起点）：

1. **关于进一步防范和处置虚拟货币等相关风险的通知**（银发〔2026〕42 号，2026-02-06 施行）——相关经营活动禁止；境外注册不是规避路径。官方原文：
<https://www.pbc.gov.cn/tiaofasi/144941/3581332/2026020619591971323/index.html>
2. **网络产品安全漏洞管理规定**（工信部，2021）——漏洞报送、负责任披露义务。官方原文：
https://www.cac.gov.cn/2021-07/13/c_1627761607640342.htm
3. **区块链信息服务管理规定**（国家网信办令第 3 号）——适用范围、安全评估、备案。官方原文：
https://www.cac.gov.cn/2019-01/10/c_1123971164.htm
4. **生成式人工智能服务管理暂行办法**（七部门令第 15 号）——适用范围、评估备案。官方原文：
https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm

5. 中华人民共和国个人信息保护法——最小必要、委托处理、出境条件。官方原文：
https://www.cac.gov.cn/2021-08/20/c_1631050028355286.htm

6 路线图与停线条件

阶段	内容	出口条件
阶段 0：权利和边界	盘点原项目代码许可与研究资产；确定经营主体、试点合同/授权、数据流、禁止功能	授权与数据处理方案成文；未完成不接触真实客户资料
阶段 1：离线样机	仅合成数据跑通授权门禁、正常/攻击配对、可信事件、四态裁决、报告与回归	确定性目标验收管线，不宣称模型结论
阶段 2：封闭客户试点	客户签字的脱敏夹具、固定环境与停止条件，人工复核与整改复测	试点验收报告 + 客户签收
阶段 3：可重复服务	标准化合同与数据处理附件、适配器、版本化报告、年度回归	先验证付费意愿与交付成本，再决定私有化产品
阶段 4：受邀挑战活动（可选）	身份、隔离、配额、审核、披露、奖励规则均可验收后启动	RTM 不回归商业路线

90 天建议计划（非承诺）：0–30 天选择 1 个授权企业场景、签协议、数据脱敏、剥离代币与外部资金接口；31–60 天跑通对照测评、修复复核和报告；61–90 天客户验收与第三方复核，明确是否进入付费试点。验收目标预先约定、报告样本数和分母，不捏造效果。

停线条件（任一命中先暂停，不以"先上线再补"替代审查）：授权不清；无法可靠隔离客户代码/数据；证据无法独立复核；评分可被目标操控；错误被算作通过；真实资金路径无法切断；敏感数据拟未经授权外传。

7 团队与对接诉求

- 团队现状：研究原型作者与开发协作者；无销售、无客服、无专职法务（依阶段补充）。
- 对接诉求：1–2 家有智能体落地需求的园区企业（试点）；创业孵化与合规辅导、知识产权与公司设立咨询；高校或检测机构的联合验证。资金、场地、算力支持可讨论，但不假设已有补贴政策、政府背书或监管豁免。

8 主要风险与应对

风险	应对
合规定性变化（虚拟货币、AI 服务、漏洞报送）	商业版与历史研究实质隔离；发布门禁（律师审查 + 数据流梳理 + 隔离测试）；表述红线（不称"已合规/已批准"）
客户数据泄露	合成优先、脱敏、最小化、租户隔离、保留删除策略、私密漏洞处置流程
评测结果被质疑	预注册判据、宿主账本证据、可复现步骤、人工复核签收；区分"模拟通过"与"生产安全"
修复服务责任边界	只交付测试/验证结论与回归证据，不替客户上线；"自动修复可上线"不在承诺范围

单点依赖研究原型	评测内核按许可与权利盘点结果独立实现或抽取；复制代码前核对权利归属
----------	-----------------------------------

9 推荐对外表述

推荐："REDTEAM 目前已有本地合成支付场景和攻防评测研究原型；我们拟将可复核的评测能力重构为企业封闭授权的智能体安全评测服务，首期不发币、不碰真实资金、不开放公共攻击平台。"

禁止："已获合规认证/监管批准""已服务若干企业""可对所有 AI 系统给出安全保证""哈希日志不可篡改""演示代币是已上线商业激励"，以及任何未经证实的营收、客户数量与市场数字。

本文档与开源研究仓库的对应关系：研究原型见 <https://github.com/Fishman-free/REDTEAM>；商业计划与历史研究组件（代币/奖励合约）实质隔离。